

GRC 102 Week 3 Practical Laboratory

TechGlobal Security Governance Transformation

Prepared for	TechGlobal (simulation) — Board of Directors and Executive Leadership
Prepared by	Oluwatosin Olajubu, Lead Security Governance Consultant
Registration number	C11/26/CGRCE/217602
Course	GRC102 – Governance, Risk and Compliance, Week 3 Practical Laboratory
Evidence bundles	Six bundles (1–6), each labelled and cross-referenced to the laboratory brief

Evidence bundles in this report

Bundle 1 — Governance architecture: gap assessment, stakeholder map, organisation chart, justification

Bundle 2 — Roles and responsibilities: responsibility matrix, role profiles, conflict-resolution analysis

Bundle 3 — Committee ecosystem: interaction diagram, Terms of Reference, agenda, decision log, 12-month calendar

Bundle 4 — RACI accountability matrix and implementation guide

Bundle 5 — Cyber-risk escalation workflow and threshold table

Bundle 6 — Segregation-of-duties and accountability weakness register, and assurance note

Contents

Executive summary	3
Evidence Bundle 1 — Governance Architecture and Stakeholder Map	4
1.1 Governance gap assessment	4
1.2 Stakeholder map	4
1.3 Security Governance Organisation Chart	5
1.4 Consultant justification	6
Evidence Bundle 2 — Roles, Responsibilities and Authority	8
2.1 Cross-functional Governance Responsibility Matrix	8
2.2 Role profiles	8
2.3 Conflict-resolution analysis	12
Evidence Bundle 3 — Security Governance Committee Ecosystem	13
3.1 Committee structure and interaction	13
3.2 Terms of Reference — Security Governance Committee	14
3.3 Sample committee agenda	15
3.4 Sample decision log	15
3.5 12-month governance calendar	16
Evidence Bundle 4 — RACI Accountability Matrix	17
4.1 TechGlobal RACI matrix	17
4.2 Problematic assignments	17
4.3 Implementation guide — one page	18
Evidence Bundle 5 — Cyber-Risk Escalation and Segregation of Duties	19
5.1 Major cyber-risk escalation workflow	19
5.2 Escalation threshold table	19
Evidence Bundle 6 — Segregation-of-Duties and Accountability Weakness Register	21
6.1 Weakness register	22
6.2 Decision-recording and assurance note	22
References	23

Executive summary

TechGlobal has grown to about 2,500 employees across five offices while its security governance has stayed informal: the IT Director owns, operates and approves security risk with no committee structure, no consistent business-unit practice and no reliable path to executive or Board attention. This report redesigns that model into a structured, business-aligned governance framework and delivers the six evidence bundles the brief requires.

What this report delivers

Bundle 1. Nine governance gaps with business consequences, a stakeholder map (current versus proposed authority and interest), a governance organisation chart, and a justification for why this structure fits a 2,500-person, five-office technology company.

Bundle 2. A responsibility matrix and full role profile for all nine roles (the eight named in the brief plus Business Unit Leaders, who own local risk in the stakeholder table), each with purpose, responsibilities, decision authority, reporting line and at least two measurable KPIs plus five overlap-and-conflict areas with resolution rules.

Bundle 3. A four-forum committee ecosystem (Board committee, Executive Security Council, Security Governance Committee, and an Incident Response & Resilience Working Group) with a Terms of Reference, a timed sample agenda, a four-entry decision log and a 12-month governance calendar.

Bundle 4. A 17-activity RACI matrix — the 15 required activities plus two I added because TechGlobal's risk profile needs them explicitly — validated so each activity has exactly one accountable role, with three problem assignments explained and a one-page implementation guide.

Bundle 5. A seven-step escalation workflow from detection to Board decision, a three-level threshold table with named triggers, decision authority, notification and target response times, and a note on how decisions are recorded, tracked and closed.

Bundle 6. Eight segregation-of-duties and accountability weaknesses (the brief asks for at least five), each with the risk created, roles involved, a proportionate corrective control and a residual-risk rating.

Evidence Bundle 1 — Governance Architecture and Stakeholder Map

1.1 Governance gap assessment

In TechGlobal's current model, I identified nine weaknesses and each of them is linked to a business or risk consequence and, where relevant, to the governance reference it fails to meet.

Table 2 – Governance gap assessment

ID	Weakness	Why it exists	Business / risk consequence	Severity	Reference
G1	Authority concentrated in the IT Director , who acts as security owner, risk approver and operator.	The same person designs, runs, reviews and accepts risk on the technology they operate.	Self-review with no independent challenge; risks that inconvenience IT go unrecorded; key-person dependency; weak credibility with customers and auditors.	High	ISO 27001 5.3, A.5.3; IIA Three Lines
G2	No formal governance committees.	No forum exists to decide funding, exceptions, priorities or notification questions across functions.	Cross-functional decisions are ad hoc, slow or never taken; outcomes depend on who is asked.	High	ISO 27014 (evaluate, direct, monitor)
G3	Inconsistent business-unit security decisions.	BUs make local choices with no common standard or risk-acceptance criteria.	Uneven control coverage across five offices; the weakest unit sets the group's risk; repeated customer-audit findings.	High	NIST CSF GV.PO, GVRM
G4	No reliable escalation path or thresholds.	Nothing defines when an event becomes an executive or Board matter, or who decides.	Material incidents are recognised late; notification clocks (for example 72 hours under GDPR Art. 33) are missed; damage and penalties grow.	High	GDPR Art. 33; NIS2 Art. 23
G5	Limited CEO and Board visibility of cyber risk.	No metrics, no reporting rhythm and no direct channel to the Board.	Directors cannot discharge oversight duties; risk appetite is undefined; investment is not risk-informed.	High	NIS2 Art. 20; NIST CSF GV.OV
G6	Security leadership lacks independence and clear authority.	Security reports through IT and competes with delivery priorities.	Findings can be filtered or softened; security requirements are traded against deadlines; security budget depends on IT.	High	NIST CSF GV.RR; ISO 27001 5.3
G7	No enterprise risk integration.	Cyber risks sit outside any enterprise risk register or aggregation method.	Risks are accepted locally without a consolidated view; insurance and financial planning are not aligned to exposure.	Medium	NIST CSF GVRM; ISO 27001 6.1
G8	Unclear control ownership across functions.	HR, Legal and Finance are not linked to security controls.	Gaps appear between functions: leavers keep access, supplier contracts lack breach-notice terms, funding is not risk-ranked.	Medium	ISO 27001 A.5.2; NIST CSF GV.RR
G9	No auditable decision trail.	Decisions are made verbally or by email and are not tracked to closure.	Cannot evidence due care to regulators, insurers or enterprise customers; the same disputes recur.	Medium	ISO 27001 7.5; NIST CSF GV.OV

1.2 Stakeholder map

Table 3 sets out authority, interests, information needs and expected contribution for all nine stakeholder groups named in the brief's stakeholder table (Business Unit Leaders included). Figure 4 plots each stakeholder's current position against the position the proposed model gives them, on two axes: authority/influence over security decisions and interest/engagement in governance. The IT Director's authority is deliberately reduced from where it sits today (concentrated, top-right) to a bounded operational role, while the CISO, CRO and Board move to genuine authority with sustained engagement.

Table 3 – Stakeholder map: authority, interest, information and contribution

Stakeholder	Authority / influence	Primary interest	Information needed	Governance contribution
Board of Directors	Very high. Final authority on risk appetite and material risk.	Regulatory exposure, reputation, material risk, assurance, personal accountability.	Quarterly cyber dashboard, top risks against appetite, material incidents, assurance results, unfunded risk.	Sets appetite; approves strategy; challenges management; accepts risk outside appetite.
CEO	Very high. Executive accountability and crisis authority.	Growth, strategic alignment, acceptable risk, business performance.	Risk versus appetite, investment case, incident impact, decisions needed.	Chairs Executive Security Council; approves policy; decides in a crisis; resources the model.

Stakeholder	Authority / influence	Primary interest	Information needed	Governance contribution
CISO	Medium now, high in the model. Owns security governance.	Strategy, policy, risk oversight, reporting, programme effectiveness.	Control performance, incident trends, vulnerability ageing, exceptions, third-party status.	Chairs the Security Governance Committee; sets standards; reports directly to CEO and Board.
CRO / Risk	High. Owns risk method and acceptance register.	Consistent method, aggregation, appetite, independent challenge.	Cyber risks, treatment progress, acceptances, key risk indicators.	Challenges risk decisions; aggregates cyber risk; owns third-party and continuity frameworks.
Legal / Compliance	High on notification and contracts.	Regulatory duties, contracts, privacy, evidence, notification.	Incident facts, data categories, regulator clocks, contract exposure.	Decides notifiability; advises on privilege and contracts; tracks regulatory change.
Finance	High on funding.	Budget, loss exposure, investment priority, financial controls, insurance.	Cost of risk, incident cost, budget variance, unfunded risks.	Funds risk-ranked priorities; owns loss quantification and insurance; disclosure controls.
Human Resources	Medium.	Joiner-mover-leaver controls, awareness, conduct, discipline.	Leaver timeliness, training completion, insider-risk cases.	Owns people controls; runs awareness delivery and disciplinary process with Legal.
IT / Technology	Very high now; high but bounded in the model.	Secure operation, delivery, control ownership, service continuity.	Standards, remediation SLAs, change calendar, architecture decisions.	Operates and remediates controls; delivers within standards; requests exceptions through governance.
Business Unit Leaders	Medium-high; owners of local risk.	Performance, delivery speed, local risk decisions, control implementation.	BU risk exposure, requirements, exception route, scorecard.	Own and sign BU risks; nominate champions; implement controls; escalate through the SGC.

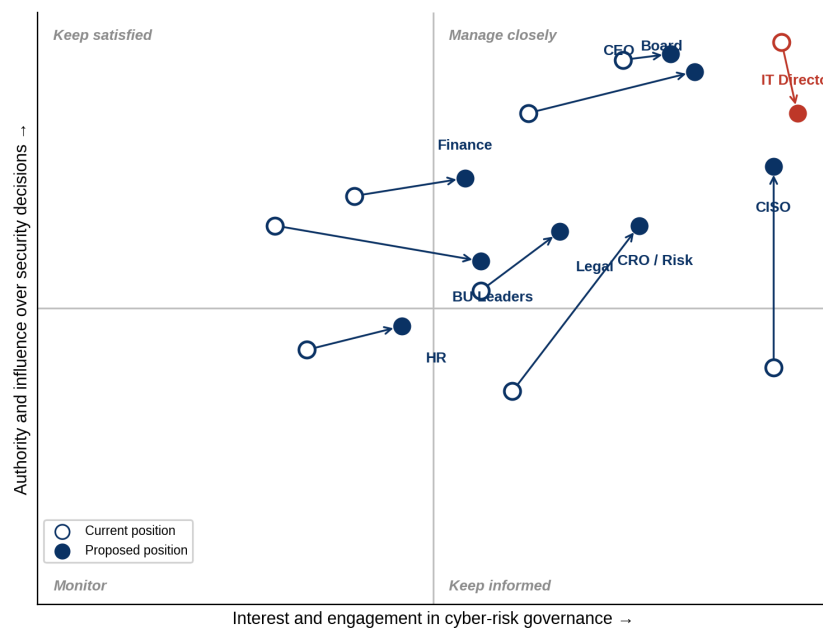


Figure 3 – Stakeholder power/interest grid: current position (open circle) versus proposed position (filled circle) under the new model.

1.3 Security Governance Organisation Chart

Figure 5 shows reporting lines (solid), direct unfiltered escalation access to the Board Audit & Risk Committee (dashed red), and functional/communication lines (dotted). The CISO moves out of the IT reporting line entirely and reports to the CEO, with a protected route to the Board committee alongside the CRO and Internal Audit. The IT Director remains an important operational leader but no longer approves the risk created by their own function.

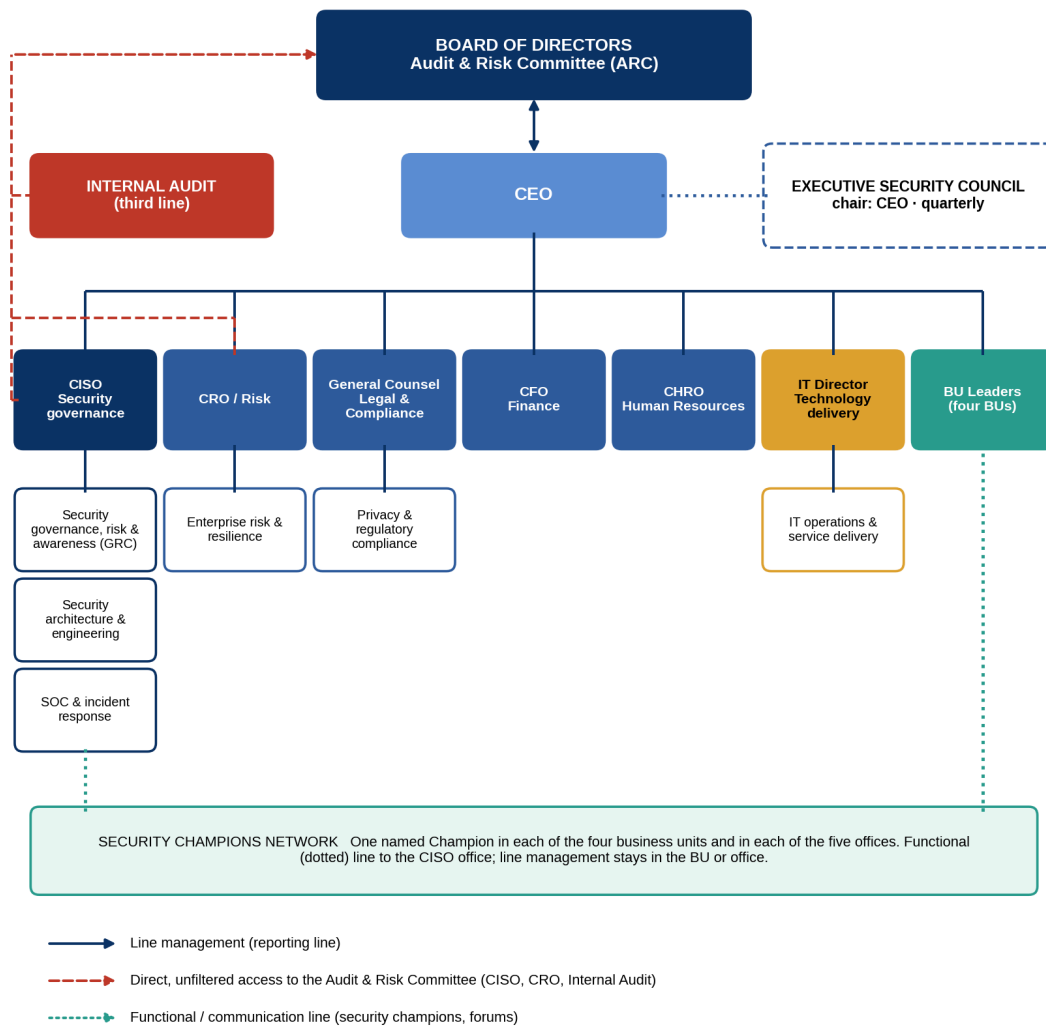


Figure 4 – Proposed Security Governance Organisation Chart for TechGlobal.

1.4 Consultant justification

Why this structure fits a 2,500-employee, five-office technology company. The design responds directly to TechGlobal’s scale and shape, not to a generic template.

1. **Size justifies a light but real committee structure.** At 2,500 employees, a heavier structure (multiple sub-committees per domain) would be bureaucratic; a single informal owner, as today, cannot service five offices and four business units. Three governance forums plus one working group is the minimum that separates strategic oversight (Council), cross-functional operating decisions (Security Governance Committee) and technical readiness (Incident Response & Resilience Working Group) without duplicating effort.
2. **Five offices need a named, funded local voice rather than five parallel security functions.** The Security Champions Network (Bundle 3) gives every office and business unit a two-way channel into the Security Governance Committee without letting any of them build a private security programme, which is the practical failure mode of “inconsistent business-unit security decisions” named in the brief.
3. **Removing the IT Director’s combined role is proportionate, not punitive.** The IT Director keeps full accountability for operating and remediating controls — the job the function is actually resourced and skilled to do — while an independent CISO takes governance and a CRO takes risk challenge. This directly targets Gap G1 without adding headcount beyond a CISO function TechGlobal will need regardless of governance design.
4. **Board-level oversight is proportionate to TechGlobal’s risk, not oversized.** A dedicated cyber sub-board is not justified at this scale; routing oversight through the existing Audit & Risk Committee,

with quarterly cyber items and a 72-hour extraordinary-meeting option for material events, gives the Board real visibility without creating a new governance layer.

5. **The model scales with growth.** Each element (RACI, thresholds, committee ToR) is reviewed annually, so as TechGlobal adds offices or business units, the same structure absorbs them by adding Champions and rotating committee seats rather than by redesigning governance from scratch.

Evidence Bundle 2 — Roles, Responsibilities and Authority

2.1 Cross-functional Governance Responsibility Matrix

Table 4 summarises purpose, core responsibility, decision authority, reporting line and headline KPI for each role. Full role profiles with complete responsibility lists, decision rights, escalation routes and all KPIs follow in section 2.2, using the brief's Appendix B template extended with an escalation column.

Table 4 – Governance Responsibility Matrix (summary)

Role	Purpose	Core responsibility	Decision authority	Reports to	Headline KPI
Board (Audit & Risk Committee)	Oversee cyber risk as an enterprise risk and set the risk appetite.	Approve strategy and appetite; challenge management; accept risk outside appetite; oversee assurance.	Approves strategy and risk appetite; sole authority for Critical or out-of-appetite risk acceptance; endorses CISO appointment.	Receives reports from CEO, CISO, CRO, Internal Audit.	Cyber items held 4 of 4 quarters; 100% of material decisions minuted.
CEO	Own enterprise security outcomes and integrate security with strategy.	Chair the Executive Security Council; approve policy; resource the model; lead crisis decisions.	Approves policy; accepts High risk within appetite; decides ransom and crisis matters after consulting the Board Chair.	Reports to the Board; CISO and CRO report to the CEO.	Level 3 council convened within 4 h; High risk acceptances decided within 10 business days.
CISO	Lead security governance and give management and the Board a truthful view of cyber risk.	Strategy, policy, standards, risk oversight, incident command, reporting, assurance of controls.	Sets standards; approves security architecture and privileged-access policy; declares major incidents; may stop a release with an unmitigated Critical finding.	Reports to CEO; direct line to Board committee.	Critical/High remediation SLA $\geq$ 90%; 100% of Level 2+ events escalated within time.
CRO / Risk	Integrate cyber risk into enterprise risk and give independent challenge.	Risk method, register, appetite metrics, challenge of acceptances, third-party and continuity frameworks.	Owens the risk-acceptance register; may challenge and escalate any acceptance; approves risk method.	Reports to CEO; direct line to Board committee.	100% of acceptances independently challenged; 0 expired acceptances.
Legal / Compliance	Ensure legal, privacy and contractual duties are met and evidenced.	Notification decisions, privilege, contract security terms, regulatory horizon scanning.	Decides whether and when regulators and individuals are notified; approves external statements with the CEO.	General Counsel reports to CEO.	Notification decision within 24 h of facts; 100% Tier 1 contracts with security terms.
Finance	Fund risk-ranked security priorities and control financial exposure.	Budget process, loss quantification, cyber insurance, payment controls, disclosure controls.	Owens funding process; validates business cases; never sole approver of a payment to an attacker.	CFO reports to CEO.	Security spend within $\pm$ 10% of plan; insurer notified within policy period.
Human Resources	Embed security in the employee lifecycle and conduct.	Joiner-mover-leaver, awareness delivery, conduct, disciplinary process, insider-risk cases.	Decides disciplinary outcomes with Legal; owns joiner-mover-leaver triggers.	CHRO reports to CEO.	Leaver access removed within 24 h $\geq$ 98%; awareness completion $\geq$ 95%.
IT / Technology	Deliver and operate secure technology within governance standards.	Operate and remediate controls, provision access, patch, back up, recover services.	Operates and changes systems within standards; provisions (but does not approve) access; requests time-boxed exceptions.	IT Director reports to CEO; reports control performance to CISO.	Remediation SLA $\geq$ 90%; privileged MFA 100%.
Business Unit Leaders	Own local risk and implement controls without creating silos.	Sign BU risks, nominate champions, implement controls, recertify access.	Accept Low and Medium risk in their unit within the standard; propose exceptions.	Report to CEO; escalate through the Security Governance Committee.	100% BU risks owned and signed; training $\geq$ 95%.

2.2 Role profiles

Each profile below states purpose, full responsibilities, decision authority, escalation route, reporting obligations and at least two KPIs with an evidence source, satisfying the brief's requirement in full for the eight core roles plus Business Unit Leaders.

Board (Audit & Risk Committee)

Purpose	Provide independent oversight of cyber risk so that management's security decisions are aligned with risk appetite, strategy and legal duties.
Core responsibilities	- Approve the cybersecurity strategy and annual risk appetite statement. - Challenge the quarterly cyber-risk dashboard, top risks and unfunded risks. - Receive independent assurance from the CRO and Internal Audit, including private sessions with the CISO twice a year. - Oversee material-incident response and regulatory exposure.
Decision authority	- Cybersecurity strategy and risk appetite. - Acceptance of any Critical risk or risk outside appetite. - Endorsement of CISO appointment and removal.
Escalates / refers	Refers legal or governance failures to the full Board.

Reporting obligations	• Receives a quarterly cyber dashboard (CISO and CRO) and an annual Internal Audit opinion. • Chair is informed within 24 hours of a Level 3 determination.
------------------------------	--

Performance indicators

KPI	Target	Evidence source
Cyber-risk items reviewed at Audit & Risk Committee meetings	4 of 4 per year	Committee minutes
Material decisions with a recorded rationale	100%	Decision & Risk Register
Directors completing annual cyber briefing	100%	Board secretary

CEO

Purpose	Be accountable to the Board for security outcomes and ensure the CISO has the independence, authority and resources to govern security.
Core responsibilities	• Chair the Executive Security Council and enforce its decisions. • Approve information security policy and delegate authority through the tiered authority matrix. • Protect CISO independence, including direct Board access. • Take crisis decisions on Level 3 events, including any ransom demand.
Decision authority	• Information security policy. • Risk acceptance within appetite up to High rating. • Ransom, disclosure and crisis decisions (Board Chair consulted).
Escalates / refers	• Any Critical risk or out-of-appetite matter to the Board committee.
Reporting obligations	• Reports strategy, top risks and material incidents to the Board. • Receives CISO and CRO reports directly and unfiltered.

Performance indicators

KPI	Target	Evidence source
Level 3 events with council convened within 4 hours	100%	Escalation log
High risk acceptances decided within 10 business days	≥ 90%	Decision & Risk Register
Executive Security Council meetings held	4 of 4 per year	Council minutes

CISO

Purpose	Establish and run the security governance system, and report on cyber risk honestly and directly to the CEO and Board.
Core responsibilities	• Develop strategy, policy and standards; chair the Security Governance Committee. • Assess and report cyber risk, control performance and incident trends. • Command major incidents and ensure escalation follows the thresholds. • Monitor IT and BU control operation and report exceptions.
Decision authority	• Security standards and architecture approvals. • Privileged-access policy and access-recertification requirements. • Declaration of a major incident; stop-release on an unmitigated Critical finding (appealable to the council).
Escalates / refers	• Risks needing acceptance above Medium to CRO, CEO or the Board. • Any disagreement not resolved in five business days.
Reporting obligations	• Monthly to the committee, quarterly to the council and the Board committee; ad hoc within escalation times.

Performance indicators

KPI	Target	Evidence source
Critical and High vulnerabilities remediated within SLA	≥ 90%	Vulnerability platform
Level 2 and 3 events escalated within threshold time	100%	Escalation log
Board dashboard delivered on schedule	4 of 4 per year	Board papers
Privileged accounts recertified each quarter	100%	Access-review records

CRO / Risk

Purpose	Ensure cyber risk is assessed, aggregated and accepted consistently and independently of those who run the controls.
Core responsibilities	• Own the enterprise risk method and cyber-risk register. • Challenge risk assessments and acceptances; report aggregated exposure against appetite. • Own the third-party risk framework and supplier tiering. • Own business-continuity and resilience governance.
Decision authority	• Risk rating method and register content. • Third-party tiering and acceptance within delegated limits.
Escalates / refers	• Any acceptance outside appetite or lacking an owner to the CEO and Board committee.
Reporting obligations	• Quarterly independent risk view to the council and the Board committee.

Performance indicators

KPI	Target	Evidence source
Risk acceptances independently challenged before approval	100%	Risk register
Expired or overdue risk acceptances	0	Risk register
Cyber risks reviewed each quarter	100%	Register review log

Legal / Compliance

Purpose	Protect TechGlobal's legal position and ensure regulatory and contractual obligations are identified and met on time.
Core responsibilities	• Determine notifiability and run the regulatory-clock tracker during incidents. • Direct investigations under privilege and preserve evidence. • Maintain contract security and breach-notice clauses. • Report regulatory change and enforcement trends to the committee.
Decision authority	• Legal notification determinations and their timing. • Contract security clause standards.
Escalates / refers	• Any decision to delay or not notify, to the CEO with Board Chair informed.
Reporting obligations	• Notification status to the council during incidents; quarterly regulatory update to the committee.

Performance indicators

KPI	Target	Evidence source
Notification determination within 24 hours of confirmed facts	100%	Regulatory-clock tracker
Statutory notification deadlines met	100%	Tracker
Tier 1 and 2 contracts with security and breach-notice terms	100% of new; 100% of renewals within 12 months	Contract register

Finance

Purpose	Ensure security investment is prioritised by risk, financed transparently and supported by sound loss and insurance arrangements.
----------------	---

Core responsibilities	• Run the security budget cycle and validate business cases. • Quantify loss exposure for the risk register and Board dashboard. • Manage cyber insurance and insurer-notice duties. • Report unfunded risks to the council and Board.
Decision authority	• Funding envelope and release of funds within delegated limits.
Escalates / refers	• Unfunded High or Critical risks to the council and Board committee.
Reporting obligations	• Cost-of-risk and budget variance to the council quarterly.

Performance indicators

KPI	Target	Evidence source
Security spend variance to approved plan	within $\pm 10\%$	Finance system
Unfunded High or Critical risks with cost estimate	100%	Risk register
Insurer notified within policy period after a Level 3 event	100%	Incident file

Human Resources

Purpose	Ensure people-related controls operate reliably and that conduct expectations are enforced consistently.
Core responsibilities	• Operate the joiner-mover-leaver process and feed access changes to IT. • Deliver mandatory awareness training and track completion. • Run disciplinary and insider-risk cases with Legal and the CISO. • Support screening and role-based security requirements.
Decision authority	• Disciplinary outcomes for security breaches. • Mandatory training requirements.
Escalates / refers	• Suspected insider misconduct to Legal and the CISO immediately.
Reporting obligations	• Joiner-mover-leaver and training metrics to the committee monthly.

Performance indicators

KPI	Target	Evidence source
Leaver access removed within 24 hours of exit	$\geq 98\%$	IAM and HR system reconciliation
Awareness training completion	$\geq 95\%$	Learning platform
Security-related disciplinary cases closed within policy time	100%	HR case system

IT / Technology

Purpose	Run technology reliably and securely, and be visibly accountable for operating the controls that governance sets.
Core responsibilities	• Operate patching, configuration, backup and recovery to standard. • Provision access only on approved requests. • Deliver remediation plans within SLA. • Provide logs and forensic support for incidents.
Decision authority	• Technical implementation within approved standards and architecture.
Escalates / refers	• Any inability to meet a standard, through a time-boxed exception, never by silent deviation.
Reporting obligations	• Monthly SLA, patch and configuration compliance to the CISO; vulnerability ageing to the committee.

Performance indicators

KPI	Target	Evidence source
Critical and High findings remediated within SLA	$\geq 90\%$	Vulnerability platform

KPI	Target	Evidence source
Privileged accounts with phishing-resistant MFA	100%	IAM report
Restore tests passed each quarter	100%	Recovery test records

Business Unit Leaders

Purpose	Own the security risk created by business decisions and ensure controls operate in their unit.
Core responsibilities	• Act as named risk owner for BU risks and sign acceptances within authority. • Nominate a Security Champion per BU and per office. • Ensure access recertification and awareness are completed. • Include security requirements in BU plans and change requests.
Decision authority	• Low and Medium risk acceptance within standards and expiry limits.
Escalates / refers	• High risks and any request to deviate from a standard, through the committee.
Reporting obligations	• BU scorecard to the committee monthly (through the Champion).

Performance indicators

KPI	Target	Evidence source
BU risks with a named owner and signed treatment	100%	Risk register
BU access recertifications completed on time	≥ 95%	Access-review records
BU staff awareness completion	≥ 95%	Learning platform

2.3 Conflict-resolution analysis

At least three overlap-or-conflict areas are required; five are analysed below because TechGlobal's informal model creates several simultaneously. Each states the tension, the resolution principle built into the model, and where an unresolved disagreement goes next.

Table 5 – Overlapping authority: tension, resolution principle and escalation route

Overlap area	Nature of the tension	Resolution principle	Unresolved disagreement goes to
CISO and CRO: who rates and who accepts risk	Both assess risk; if the CISO also accepts it, the assessor marks their own homework.	Risk owners accept; the CISO assesses and recommends; the CRO challenges and records. Nobody accepts a risk they assessed alone.	Disagreement on rating goes to the Security Governance Committee, then the Executive Security Council.
CISO and IT Director: standards versus delivery	IT wants delivery speed and flexibility; the CISO sets binding standards and approves architecture.	CISO decides security standards and architecture; IT decides how to implement within them. A stop-release right applies only to unmitigated Critical findings.	Appeal to the council within five business days; the release is held meanwhile.
Legal and CISO/CEO: notification and disclosure	Technical teams may prefer to finish the investigation first; Legal must meet statutory clocks; the CEO manages reputation.	Legal makes the notifiability determination on facts supplied by the CISO. It may be overridden only by a recorded CEO decision with the Board Chair informed.	Board Chair, through the Audit & Risk Committee.
Finance and CISO: funding versus risk	Finance may defer spend that the CISO ranks as critical to risk reduction.	Finance owns the envelope; the CISO owns the risk-ranked case. Any unfunded High or Critical risk is reported to the council and Board.	Council decides; Board sees unfunded risks.
BU Leaders and CISO: local risk decisions	BU leaders under delivery pressure accept risks locally or bypass standards.	Local choice is permitted only within the standard and within Low/Medium authority. Deviations need a time-boxed exception recorded in the register.	Security Governance Committee; escalate to CEO if unresolved.

Evidence Bundle 3 — Security Governance Committee Ecosystem

3.1 Committee structure and interaction

Figure 6 shows how four forums connect operational decisions to the Board: the Executive Security Council for strategic oversight (as the brief requires), the Security Governance Committee for cross-functional governance decisions, the Incident Response & Resilience Working Group as the specialised working group, and the BU and Regional Security Champions Network as the route for business-unit participation. Table 5 defines each forum's purpose, chair, membership, frequency and typical decisions.

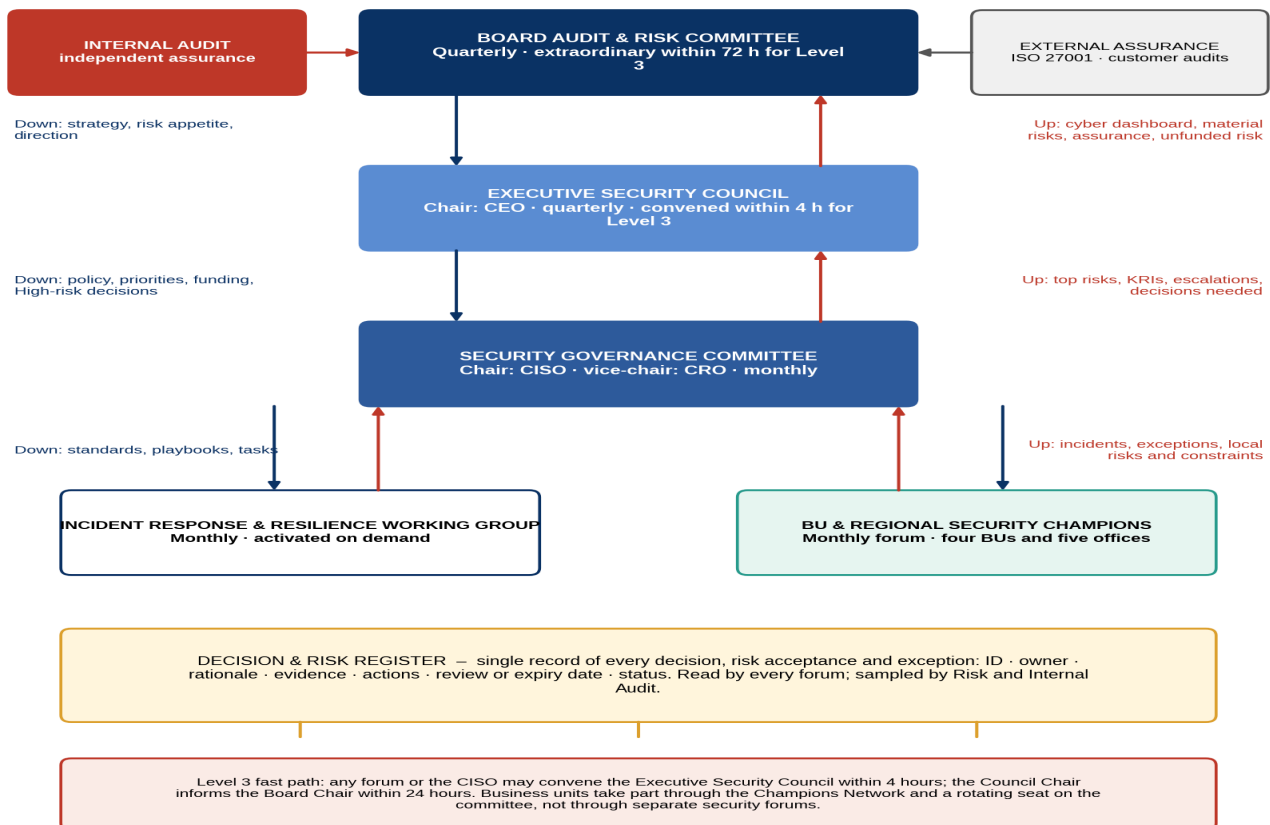


Figure 5 – Security Governance Committee ecosystem: composition, cadence and information flow.

Table 6 – Governance forums: purpose, chair, membership, frequency and decisions

Forum	Purpose	Chair	Membership	Frequency	Typical decisions
Board Audit & Risk Committee (ARC)	Independent oversight of cyber risk, appetite and assurance.	Committee Chair	Non-executive directors; CEO, CISO and CRO attend by invitation; Internal Audit.	Quarterly; extraordinary within 72 h for Level 3.	Approves strategy and appetite; accepts Critical or out-of-appetite risk; receives assurance.
Executive Security Council (ESC)	Strategic oversight, investment, top risks and Level 2 and 3 decisions.	CEO	CFO, General Counsel, CHRO, IT Director, CISO, CRO, two rotating BU Leaders.	Quarterly, two weeks before the ARC; convened within 4 h for Level 3.	Approves policy and High risk acceptance; sets priorities and funding; escalates to the ARC.
Security Governance Committee (SGC)	Cross-functional governance: standards, exceptions, risk register, metrics, third-party and regulatory items.	CISO (CRO as vice-chair)	Senior delegates from IT, Legal, Finance, HR, Risk, each BU (rotating seat per BU), regional champions' representative.	Monthly, 90 minutes.	Approves standards, exceptions, Low and Medium acceptances; refers High risk to the ESC.

Forum	Purpose	Chair	Membership	Frequency	Typical decisions
Incident Response & Resilience Working Group (IR WG)	Operational readiness, playbooks, exercises, escalation quality and post-incident learning.	Head of Security Operations	SOC, IT Operations, Legal, Communications, HR, BU champions as needed, Risk.	Monthly; activated on demand.	Owns playbooks and exercises; recommends changes to the SGC.
BU and Regional Security Champions Network	Two-way channel between the SGC and each BU and office; not a decision forum.	CISO office (Security Governance lead)	One Champion per BU and per office.	Monthly 30-minute forum.	Brings local risks and constraints to the SGC; carries decisions and training back.

How business units participate without creating silos

1. **One standard, local implementation.** BUs and offices implement one global policy set. They do not write their own.
2. **Named champions.** Each BU and each of the five offices names a Security Champion with protected time (about 10%), who joins the monthly forum.
3. **Rotating BU seat on the Security Governance Committee,** plus a regional representative, so BU voice is direct.
4. **BU risk ownership.** BU Leaders sign the risks and exceptions in their unit in the shared register; no BU keeps a separate risk log.
5. **No separate BU security budgets.** A central baseline funds controls; a BU pays only for its own approved exceptions or extras.
6. **BU scorecard.** The same six measures for every BU, reviewed monthly.

3.2 Terms of Reference — Security Governance Committee

Name	Security Governance Committee (SGC)
Purpose	To provide a formal, cross-functional forum that reviews and decides security governance matters so that no single department decides them alone.
Authority	Delegated by the Executive Security Council (ESC). May approve security standards and procedures, architecture exceptions, Low and Medium risk acceptances, remediation SLAs and awareness plans. Must refer High and Critical risk acceptance, policy changes, funding above delegated limits and any Level 2 or 3 matter to the ESC.
Chair and vice-chair	Chair: CISO. Vice-chair: CRO / Head of Risk. Secretary: Security Governance lead.
Members	Senior delegates (decision-capable) from IT, Legal and Compliance, Finance, HR, Risk, each of the four BUs on a rotating seat, Head of Security Operations, and a regional champions' representative. Alternates are named in advance.
Quorum	Chair or vice-chair, plus at least one member each from IT, Legal or Risk, and Finance or HR, plus at least half of remaining members. The IT Director's delegate cannot form the quorum alone.
Frequency	Monthly for 90 minutes; extraordinary meeting within 2 business days at the request of the CISO, CRO or General Counsel.
Standing agenda	Security dashboard and key risk indicators; incidents and escalations; risk register and expiring acceptances; decisions for approval; third-party and regulatory items; BU updates; funding items; decision recap. A sample agenda is in Artefact 3.3.
Decision-making	Consensus first. Where none is reached, the Chair decides for matters within the SGC's authority; any member may require the disagreement to be minuted and referred to the ESC. Conflicted members abstain.
Conflicts of interest	A member who owns the system, project or risk being decided declares it; they may inform but do not vote on their own risk acceptance.
Records	Decisions are entered in the Decision & Risk Register within 1 business day; minutes issued within 3 business days; actions tracked to closure with owners and dates.
Reporting	A one-page summary and open-decision list to the ESC each quarter; exceptions and expiring acceptances reported to the ESC monthly if High.

Review	ToR, membership and thresholds reviewed annually (September) and after any Level 3 event.
Approval	Approved by the Executive Security Council; noted by the Board Audit & Risk Committee.

3.3 Sample committee agenda

A 90-minute monthly agenda, timed to keep the meeting disciplined and to guarantee time for business-unit and funding items that are often crowded out in practice.

Table 7 – Security Governance Committee — sample agenda (90 minutes)

Time	Duration	Item	Lead	Purpose
0:00	5 min	Opening: quorum, conflicts of interest, previous actions	Chair / Secretary	Confirm quorum; close actions
0:05	15 min	Security dashboard and key risk indicators	CISO	Note trends; agree responses
0:20	10 min	Incidents, escalations and near-misses	IR WG lead	Confirm escalation quality; lessons
0:30	15 min	Risk register: new, changed and expiring acceptances and exceptions	CRO	Decide within authority or refer to ESC
0:45	15 min	Decisions for approval: standards, architecture exceptions, remediation SLAs	CISO and item owners	Recorded decisions
1:00	10 min	Third-party and regulatory horizon	Legal / CRO	Actions on supplier or regulatory change
1:10	5 min	Business-unit and regional champion updates	Rotating BU delegate	Local risks raised
1:15	5 min	Funding and resourcing items	Finance	Funding requests and unfunded risks noted
1:20	8 min	Decision recap, action log and items to escalate to the ESC	Secretary	Log confirmed; ESC agenda items set
1:28	2 min	Any other business and close	Chair	Next meeting date

3.4 Sample decision log

Four example entries are shown (the brief asks for at least three), illustrating a policy decision, a risk acceptance, a third-party governance decision and an operational-standard decision, each with rationale and tracked actions.

Table 8 – Security Governance Committee decision log (sample entries)

ID	Date	Decision / issue	Decision owner	Decision	Rationale
D-2026-001	14 Oct 2026	Phishing-resistant MFA for all privileged and remote administrative access	CISO (approved by SGC)	Approved. Full coverage within 90 days; exceptions only through the register.	Stolen or reused credentials are a leading cause of breaches, and a policy without enforcement gives no protection.
D-2026-002	14 Oct 2026	Time-boxed risk acceptance: unsupported build server in Product & Engineering	BU Leader (Product & Engineering) as risk owner; CRO challenge; CEO approval (High)	Accepted for 90 days with compensating controls: network isolation, enhanced logging, weekly review.	Release dependency; inherent High, residual Medium. Acceptance may not be extended without a migration plan.
D-2026-003	11 Nov 2026	Third-party tiering and contract minimum of 24-hour incident notice for Tier 1 and 2 suppliers	CRO with General Counsel	Approved. Applies to new contracts now and to renewals within 12 months.	Supplier incidents are a recurring source of exposure and TechGlobal has no contractual notice today.
D-2026-004	11 Nov 2026	Remediation SLAs: Critical 7 days, High 30 days; exceptions only through the SGC	CISO	Approved. IT and engineering own remediation; the CISO reports SLA performance monthly.	Current ad hoc patching leaves exposure open for unpredictable periods and cannot be reported.

Table 9 – Decision log (continued) — actions and review date

ID	Date	Actions / owner	Review date
D-2026-001	14 Oct 2026	IT Director: deploy by 31 Jan 2027. HR: joiner-mover-leaver feed by 30 Nov. CISO: monthly coverage KPI.	13 Jan 2027
D-2026-002	14 Oct 2026	Engineering Director: migration plan by 15 Nov. CISO: verify controls by 30 Oct. CRO: register acceptance and expiry.	13 Jan 2027 (expiry)
D-2026-003	11 Nov 2026	Legal: clause library by 30 Nov. BU sponsors: Tier 1 inventory by 15 Dec. CISO: due-diligence standard by 15 Jan.	10 Feb 2027

ID	Date	Actions / owner	Review date
D-2026-004	11 Nov 2026	IT Director: dashboard by 15 Dec. Engineering Director: SLA in build pipeline by 31 Jan 2027.	10 Mar 2027

3.5 12-month governance calendar

Recurring governance activities and key milestones from October 2026 to September 2027, aligned to the committee cadence in Table 5.

Table 10 – 12-month governance calendar (● = scheduled)

Governance activity	Owner	Oct 26	Nov	Dec	Jan 27	Feb	Mar	Apr	May	Jun	Jul	Aug	Sep 27
Board Audit & Risk Committee: cyber-risk review	Board		●			●			●			●	
Executive Security Council	ESC	●			●			●			●		
Security Governance Committee	SGC	●	●	●	●	●	●	●	●	●	●	●	●
Incident Response & Resilience Working Group	IR WG	●	●	●	●	●	●	●	●	●	●	●	●
BU and Regional Champions forum	Network	●	●	●	●	●	●	●	●	●	●	●	●
Enterprise cyber-risk register refresh (before ESC)	CRO	●			●			●			●		
Regulatory horizon scan	Legal / SGC	●			●			●			●		
Privileged-access recertification (quarterly)	CISO / BUs		●			●			●			●	
Annual awareness campaign	HR / CISO	●											
Phishing simulation (quarterly)	CISO / HR			●			●			●			●
Incident tabletops: technical (Dec), executive and Board chair (Jun)	IR WG			●						●			
Policy and standards annual review	CISO				●								
Annual risk appetite and tolerance review	Board					●							
Business-continuity and recovery test	CRO / IT					●							
Third-party Tier 1 supplier reviews	CRO / CISO						●	●					
Security budget cycle (submit Apr, approve May)	Finance / CEO							●	●				
Internal Audit review of security governance	Internal Audit									●	●		
Annual governance effectiveness review (IoR, RACI, thresholds)	SGC / ESC												●

Key one-off milestones

Month	Milestone
Oct 2026	Board approves the governance charter; ESC and SGC constituted; CISO reporting line moved to the CEO; RACI and thresholds adopted.
Nov 2026	First Board cyber dashboard; Decision & Risk Register live; first privileged-access recertification.
Dec 2026	First technical tabletop; escalation thresholds tested.
Jan 2027	Policy suite re-approved under the new authority matrix; risk register baselined.
Mar–Apr 2027	Supplier tiering complete; Tier 1 reviews under way.
May 2027	Security budget approved on a risk-ranked basis; appetite statement reviewed by the Board.
Jun 2027	Executive and Board-chair tabletop completed.
Sep 2027	First annual effectiveness review; targets reset for year two.

Evidence Bundle 4 — RACI Accountability Matrix

4.1 TechGlobal RACI matrix

Table 10 covers all fifteen required activities plus two additional activities (ransom/extortion decision and security-related disciplinary action) that TechGlobal’s risk profile makes worth stating explicitly rather than leaving implicit inside “incident response governance”. The matrix was checked programmatically: every activity has exactly one accountable role (shown as A, or A/R where the same role is both accountable and responsible) and at least one responsible role.

Table 11 – TechGlobal RACI matrix — governance activities by role

Governance activity	Board	CEO	CISO	CRO/ Risk	Legal	Finance	HR	IT	BU Leader	Design rationale
Cybersecurity strategy approval	A	C	R	C	C	C	I	C	C	Board approves; CISO authors; BU input ensures alignment.
Security policy approval	I	A	R	C	C	I	C	C	C	Author (CISO) is not the approver (CEO through the council).
Enterprise cyber-risk assessment	I	I	R	A	C	C	C	R	R	CRO owns method and aggregation; CISO, IT and BUs supply assessments.
Risk acceptance	C	A	R	R	C	C	I	C	R	CEO accountable, delegating by tier; BU Leader signs as owner; CRO challenges.
Security budget approval	I	A	R	C	–	R	–	C	C	CEO approves; Finance runs the process; CISO makes the risk-ranked case.
Security architecture approval	–	–	A	I	C	–	–	R	C	IT designs and builds; CISO approves independently.
Third-party security review	–	–	A/R	C	R	C	–	C	R	CISO owns the assessment; BU sponsor and Legal contribute; acceptance follows the risk-acceptance row.
Access governance	–	–	A	I	–	–	R	R	R	CISO owns policy and recertification; IT provisions; HR and BUs supply joiner-mover-leaver and reviews.
Incident response governance	I	I	A/R	C	R	C	C	R	C	CISO owns readiness and command; IT and Legal act.
Material incident escalation	I	I	A/R	C	C	–	–	R	–	CISO ensures escalation follows thresholds; CEO is informed and holds crisis authority.
Regulatory notification decision	I	C	R	C	A/R	C	C	R	C	Legal decides notifiability; CISO and IT supply facts.
Security awareness programme	–	I	A/R	I	C	–	R	C	R	CISO owns content; HR and BUs deliver and track completion.
Vulnerability remediation oversight	–	I	A	I	–	–	–	R	R	CISO oversees SLAs; IT and engineering BUs remediate.
Business continuity / recovery governance	I	I	C	A	C	C	C	R	R	CRO owns the framework in the absence of a COO; IT and BUs execute plans.
Board cyber-risk reporting	I	C	A/R	R	C	C	–	C	I	CISO reports without filtering; CRO adds an independent view.
Ransom / extortion payment decision (extra)	C	A	R	C	R	R	–	C	–	CEO decides after consulting the Board Chair; Legal checks sanctions law.
Security-related disciplinary action (extra)	–	I	R	I	C	–	A/R	C	R	HR holds disciplinary authority; CISO supplies evidence; line manager acts.

4.2 Problematic assignments

At least three problem assignments are required; five are analysed because the informal model creates several. Each states why the assignment is problematic on its face and the resolution the model applies.

Table 12 – Problematic RACI assignments and how the model resolves them

Activity	Why the assignment is problematic	Resolution applied in this model
Risk acceptance	Several R roles and a tiered accountability. CISO, CRO and BU Leader all “R” risks the assessor accepting their own risk, or a BU accepting beyond its authority.	CEO is the single A with delegation by tier (BU Leader up to Medium; council or CEO up to High; Board for Critical or outside appetite). The assessor never accepts alone; the CRO challenges. See Artefact 5.2.
Material incident escalation	The CISO is A/R, so the same function detects, classifies and reports upward. Self-classification bias can delay escalation.	Objective thresholds decide the level, not judgement. A downgrade needs a second approver (CRO or Legal). The escalation log is sampled monthly by Risk.
Regulatory notification decision	Legal is A/R, but the CEO holds crisis authority and may want to delay for commercial reasons.	Legal’s determination stands unless overridden by a recorded CEO decision with the Board Chair informed within 24 hours.
Business continuity / recovery governance	CRO is A although IT and BUs do the work; TechGlobal has no COO, so accountability could be seen as orphaned or as second-line doing first-line work.	CRO owns the framework, testing standard and reporting; IT and BUs are R for plans and recovery. If a COO is appointed, transfer A to the COO and keep the CRO as C.

Activity	Why the assignment is problematic	Resolution applied in this model
Third-party security review	BU sponsor (R) wants the supplier onboarded quickly; CISO (A) must assess. Sponsor interest can override.	Sponsor cannot approve go-live for Tier 1 or 2 without CISO clearance; residual risk follows the risk-acceptance tiers.

4.3 Implementation guide — one page

This is the one-page guide referenced in the Required Evidence for Task 4, addressed directly to TechGlobal managers.

What the letters mean

- **A (Accountable):** one role owns the outcome and signs off. Where A/R appears, the same role also does the work.
- **R (Responsible):** does the work. Several R roles are allowed.
- **C (Consulted):** two-way input before the decision. C must be asked and its advice recorded.
- **I (Informed):** told after the decision, one way.
- **– :** no role.

Using the matrix in planning

1. Before a plan or project starts, find the activity in the matrix and name the A and the R roles on the plan.
2. If the activity is not in the matrix, ask the Security Governance lead to add it; do not proceed without an A.
3. Book consultation time with every C early. Decisions taken without C are reopened.

Using the matrix in approvals

1. Only the A can approve. Approvals are recorded in the Decision & Risk Register with rationale and evidence.
2. Risk acceptance follows the tier table: BU Leader (Low, Medium), council or CEO (High), Board (Critical or outside appetite).
3. Any A may delegate the work but not the accountability. Delegation is written and time-boxed.

Using the matrix during an incident

1. In the first hour the CISO (A) declares the level using the threshold table and names the incident commander.
2. IT and Legal (R) act on their playbook steps. The CEO is informed at Level 2 and takes crisis authority at Level 3.
3. Legal decides notification; the CEO may override only by recorded decision.
4. Every decision is logged as it is made, not afterwards.

If two roles disagree on who is Accountable

- If two roles disagree on who is A, raise it to the Security Governance Committee within one business day; unresolved disputes go to the council within five.

Review

- The RACI is reviewed each September and after any Level 3 event. Changes are approved by the council and version-controlled.

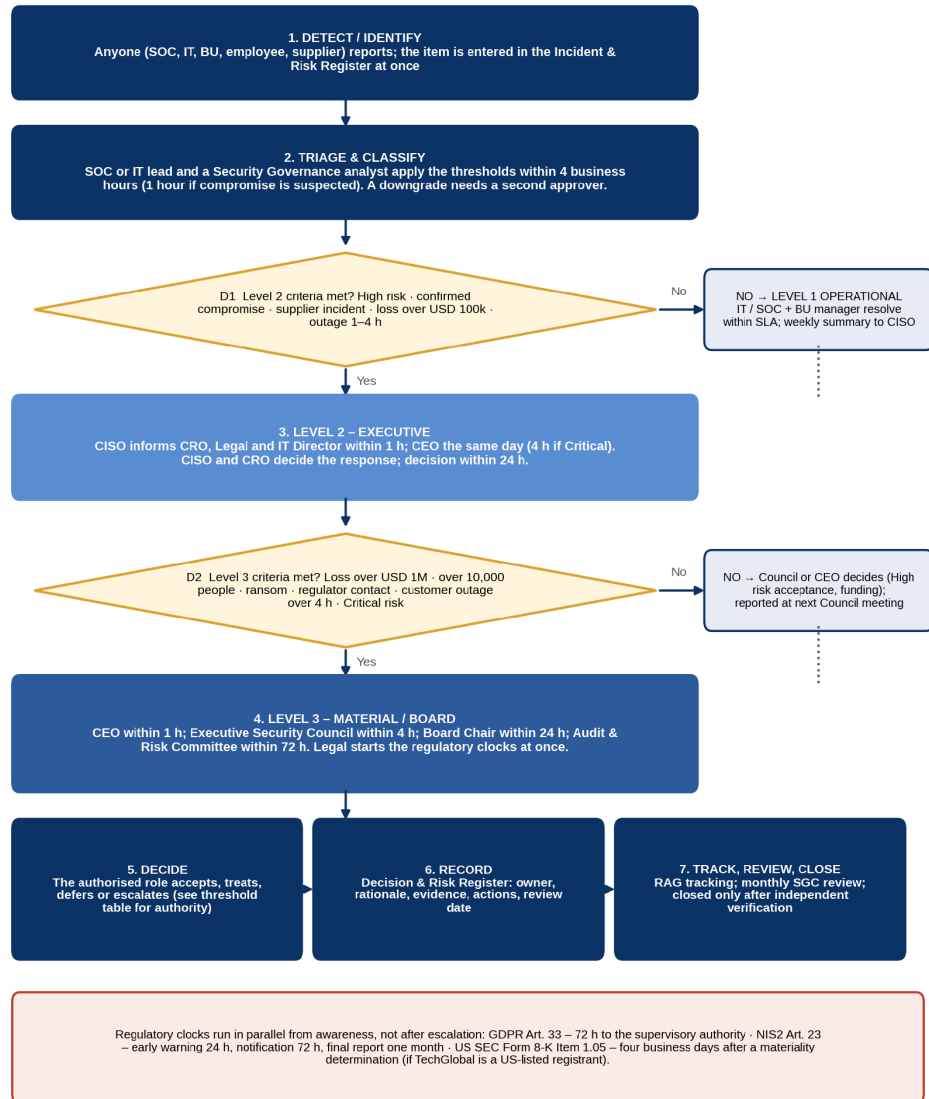
Common mistakes to avoid

- More than one A on a row; no A on a row.
- Treating C as approval.
- Treating I as involvement (I is told after, not asked).
- Letting the assessor of a risk also accept it.

Evidence Bundle 5 — Cyber-Risk Escalation and Segregation of Duties

5.1 Major cyber-risk escalation workflow

Figure 7 traces the path from detection to a Board-level decision in seven steps, with three escalation levels (Operational, Executive, Material/Board), consistent with the brief's minimum requirement. Objective criteria — not judgement — decide the level at each of the two decision points, and every step feeds a single Decision & Risk Register so the path is auditable end to end.



Lessons learned from every Level 2 and 3 event return to the Security Governance Committee to update standards, playbooks and thresholds.

Figure 6 – Major cyber-risk escalation workflow: detection through to Board decision, decide, record, track and close.

5.2 Escalation threshold table

Table 13 defines the three required levels with example triggers, decision authority, required notification and target response time, extending the brief's Appendix E template with explicit criteria so that classification does not depend on individual judgement.

Table 13 – Escalation threshold table

Level	Example triggers	Decision authority	Required notification	Target time
Level 1 – Operational	• Single endpoint malware, contained • Phishing reported, no compromise • Low or Medium vulnerability within SLA • Low or Medium risk needing a routine exception • Estimated loss under USD 100,000; fewer than 500 records	IT / SOC lead with the BU manager. Low and Medium risk acceptance by the BU Leader within the standard (CISO concurrence recorded).	Security Governance lead logs the item; weekly summary to the CISO; monthly to the SGC.	Triage within 4 business hours (1 hour if compromise suspected); resolve within SLA.
Level 2 – Executive	• Confirmed compromise of a production or corporate system • High-rated risk, or Medium risk unresolved beyond SLA + 14 days • Internet-facing Critical vulnerability unpatched at 7 days • Tier 1 or 2 supplier incident • Estimated loss USD 100,000 to 1 million; 500 to 10,000 personal records • Service outage of 1 to 4 hours	CISO with CRO decides the response. CEO or council decides High risk acceptance and funding. Legal decides on notification.	CISO informs CRO, Legal, IT Director within 1 hour; CEO same day (within 4 hours if Critical); council at the next meeting or by ad hoc call.	Decision within 24 hours; council update within 5 business days.
Level 3 – Material / Board	• Estimated loss over USD 1 million • Personal data of more than 10,000 people, or any special-category or child data • Compromise of source code, signing keys or production customer environment • Customer-facing outage over 4 hours • Ransom or extortion demand • Regulator, police or media contact • Critical risk, or any risk outside Board appetite • Senior-executive involvement	Board Audit & Risk Committee for Critical or out-of-appetite risk acceptance and final material-risk decisions; CEO decides crisis and ransom matters after consulting the Board Chair; Legal decides regulatory notification.	CEO within 1 hour; council convened within 4 hours; Board Chair within 24 hours; committee convened within 72 hours; regulators as the law requires (for example 72 hours under GDPR Art. 33; NIS2 early warning at 24 hours).	Immediate command; first decisions within 4 hours; Board decision on material risk within 72 hours.

Evidence Bundle 6 — Segregation-of-Duties and Accountability Weakness Register

6.1 Weakness register

Eight weaknesses are registered (the brief requires at least five), each with the risk created, the roles involved, a corrective control designed to be proportionate rather than bureaucratic, and a residual-risk rating with its review point.

Table 14 – Segregation-of-Duties / Accountability Weakness Register

ID	Weakness / conflict	Risk created	Roles involved	Recommended control	Residual risk
1	IT Director is security owner, risk approver and operator.	Self-approval of risk; hidden exposure; single point of failure.	IT Director; CISO; CEO	Move risk acceptance to owners with CRO challenge and CEO tiering; CISO reports to CEO; IT Director becomes control operator.	Medium. Reviewed quarterly by the SGC; Internal Audit tests annually.
2	IT administrators provision and approve privileged access and control their own logs.	Excess privilege, undetected misuse, fraud, inability to prove who did what.	IT; CISO; CRO	CISO approves privileged access; IT provisions only; just-in-time elevation; logs sent to a store admins cannot alter; quarterly recertification sampled by Risk.	Low to Medium. Quarterly recertification results to the SGC.
3	Engineering builds, changes and deploys to production without independent security review.	Vulnerable or malicious code reaches production; no separation between author and approver.	Product & Engineering BU; IT; CISO	Risk-based change approval: standard changes pre-approved, high-risk changes need a second reviewer and CISO clearance; automated security checks in the pipeline.	Medium. Change failure and defect metrics reviewed monthly.
4	BU Leaders accept risk in their own projects and can override security to meet dates.	Delivery pressure biases acceptance; risks accepted informally and never revisited.	BU Leaders; CISO; CRO	Tiered authority; every acceptance registered with expiry (Medium 6 months, High 3 months); CRO challenge; High and above visible to the council.	Medium. Expiring acceptances reviewed monthly.
5	Incident severity is self-classified and closed by the responsible team.	Under-classification delays escalation; closure without verification.	IT; SOC; CISO	Objective severity and threshold criteria; downgrades need a second approver (CRO or Legal); closure checked by someone not on the response team.	Low to Medium. Monthly sample by Risk.
6	Business sponsor selects, assesses and approves suppliers.	Weak due diligence; no independent challenge on security or contract terms.	BU sponsor; CISO; Legal; CRO	Sponsor cannot clear Tier 1 or 2 suppliers; CISO and Legal clearance required; register of suppliers and tier.	Medium. Tier 1 reviewed annually.
7	Security budget is set inside the IT budget by the IT Director.	Security competes with IT priorities; unfunded risks are invisible to the Board.	IT Director; Finance; CISO	Ring-fenced security budget proposed by the CISO on a risk basis, prioritised by Finance and approved by the CEO; unfunded risks reported to the council and Board.	Low. Reviewed at each budget cycle.
8	Reporting to the CEO and Board is produced by the function being reported on.	Filtered or optimistic reporting; no independent view.	IT Director; CISO; CRO	CISO reports directly to the CEO and Board committee; CRO adds an independent view; IT reports through the CISO's dashboard, not around it.	Low. Board sees both views each quarter.

6.2 Decision-recording and assurance note

What is recorded and where

- **What is recorded.** Every Level 2 or 3 decision, risk acceptance, exception, notification decision, ransom decision, budget change and RACI change.
- **Where.** One Decision & Risk Register (a GRC or ticketing tool). Each entry has an ID, date, decision owner, decision, rationale, evidence, actions with owners and dates, review or expiry date and status.
- **When.** Entered within 1 business day; minutes within 3 business days; urgent Level 3 decisions logged as made, with a written record by the Secretary.

How decisions are tracked

- **Tracking.** Open actions and expiring decisions are shown red, amber or green. Overdue actions escalate automatically: 7 days late to the SGC Chair, 14 days to the ESC.
- Risk acceptances send owner reminders 30 days before expiry; an expired acceptance is treated as an open High risk.

How decisions are reviewed

- **Review.** The SGC reviews open decisions monthly; the ESC reviews High decisions and overdue items quarterly; the Board committee sees a summary of exceptions and accepted risks each quarter.

How decisions are closed

- **Closure.** A decision closes only when evidence of completion is verified by someone independent of the implementer (Risk or Internal Audit sampling). Lessons feed the standards and thresholds.

Assurance across the three lines

- **Assurance across three lines.** First line (IT, BUs): quarterly self-attestation. Second line (CISO, CRO): monthly monitoring and sampling of at least 10% of decisions. Third line (Internal Audit): annual review of governance operation with the opinion reported to the Board committee. External ISO 27001 or customer audits provide additional evidence.

Retention

- **Retention.** Records are kept for at least seven years or longer where law requires.

References

- D3 Security (2026) 'What is the NIS2 Directive?' (incident-reporting stages at 24 hours, 72 hours and one month). Available at: <https://d3security.com/glossary/nis2-directive/>
- Inside Privacy (Covington) (2024) 'NIST publishes the Cybersecurity Framework 2.0', 6 March.
- International Organization for Standardization (2020) *ISO/IEC 27014:2020 Information security, cybersecurity and privacy protection: Governance of information security*. Geneva: ISO.
- International Organization for Standardization (2022) *ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection: Information security management systems: Requirements*. Geneva: ISO.
- Jones Day (2024) 'NIST extends its Cybersecurity Framework to cover evolving threats and governance', 6 March.
- National Institute of Standards and Technology (2020) *Security and Privacy Controls for Information Systems and Organizations*, SP 800-53 Rev. 5 (control AC-5, Separation of Duties). Gaithersburg, MD: NIST.
- NIS 2 Directive (n.d.) 'Article 20: Governance', Directive (EU) 2022/2555. Available at: https://www.nis-2-directive.com/NIS_2_Directive_Article_20.html
- Regulation (EU) 2016/679 (General Data Protection Regulation), Article 33: notification of a personal data breach to the supervisory authority within 72 hours.
- Securities and Exchange Commission (SEC) (2023) 'SEC adopts rules on cybersecurity risk management, strategy, governance, and incident disclosure by public companies', press release 2023-139, 26 July. Available at: <https://www.sec.gov/newsroom/press-releases/2023-139>
- The Institute of Internal Auditors (2020) *The IIA's Three Lines Model: An update of the Three Lines of Defense*. Lake Mary, FL: IIA.